

The certificate predates the feature.

Ramya Amballa, AI for U&I

INDUSTRY	SETTING	USE CASE	ENVIRONMENT	TENSION
Financial services	Qatar	Business-critical SaaS with an AI assistant	SaaS and a third-party model provider	Assurance versus actual coverage

Simulated case. Dunmore Gulf Bank (DGB), Brindlecast and Halvane AI are fictional. The bank, the provider and the evidence are fictional. No real bank, provider, incident or assessment is represented. No verification test has been performed. The governance reasoning and the work products are mine. This is not a client engagement.

A cloud provider holds a current SOC 2 report and a current ISO 27001 certificate. Then it adds an AI assistant to the platform you run a core business process on. Both documents now predate the feature. That is a timeline fact. It does not tell you the feature is covered, and it does not tell you it is not. This case shows how a bank's third-party risk team keeps three questions apart: when the assurance was issued, what it says it covers, and whether it establishes anything about this feature.

Where the case stands SIMULATED FINDING

- Five findings are open. None states a breach, non-compliance or loss of data.
- 12 verification tests have not yet been performed. Findings rest on a simulated document review.
- Whether the assistant is active in the bank's tenant, and whether any data reached the model provider, is not established.
- The renewal is 60 days away. The recommended decision is to restrict the feature pending verification.

The situation SIMULATED FINDING

A Qatar bank runs customer case management on a SaaS platform. The platform is business-critical. The bank's renewal is 60 days away.

The provider adds an AI assistant. It summarises cases and drafts replies, using a third-party model provider. Case notes can hold customer identifiers and account details.

The bank's third-party risk team asks for the usual package: the SOC 2 report, the ISO 27001 certificate, the sub-processor list and the AI and data-use terms. At first glance it looks reassuring. Then the dates stop lining up.

The question that actually mattered

Not "does the provider have SOC 2?" It does. The question is this: what does the provider's assurance actually cover, and what must be established before the bank can rely on it for this feature?

Three questions are easy to blur. I kept them apart.

1. When was the assurance issued?	Answered by the report period or certificate dates. A timeline fact. Here, both predate the launch.
2. What does it say it covers?	Answered by the system description or scope statement. Not yet examined.
3. Does that coverage establish anything about this feature?	Answered only by feature-specific verification. Not yet performed.

What the review found SIMULATED FINDING

The assurance predates the feature. The SOC 2 reporting period ends before the assistant launched. The ISO certificate was issued, and last audited, before it too. Both are established. NOT ESTABLISHED Whether either scope reaches the feature is not yet known. That the assurance predates the feature does not by itself establish that the feature is outside the assurance scope. "Predates" is a timeline observation, not a coverage conclusion. So I recorded the SOC 2 position as outside report period and the ISO position as scope unclear. Two instruments, two different evidence problems.

The model provider is named but not listed. The provider's AI documentation names the model provider. It is absent from the sub-processor list. NOT ESTABLISHED Why, and what the contract says about it, is not established. That is a discrepancy to resolve, not a

breach to allege.

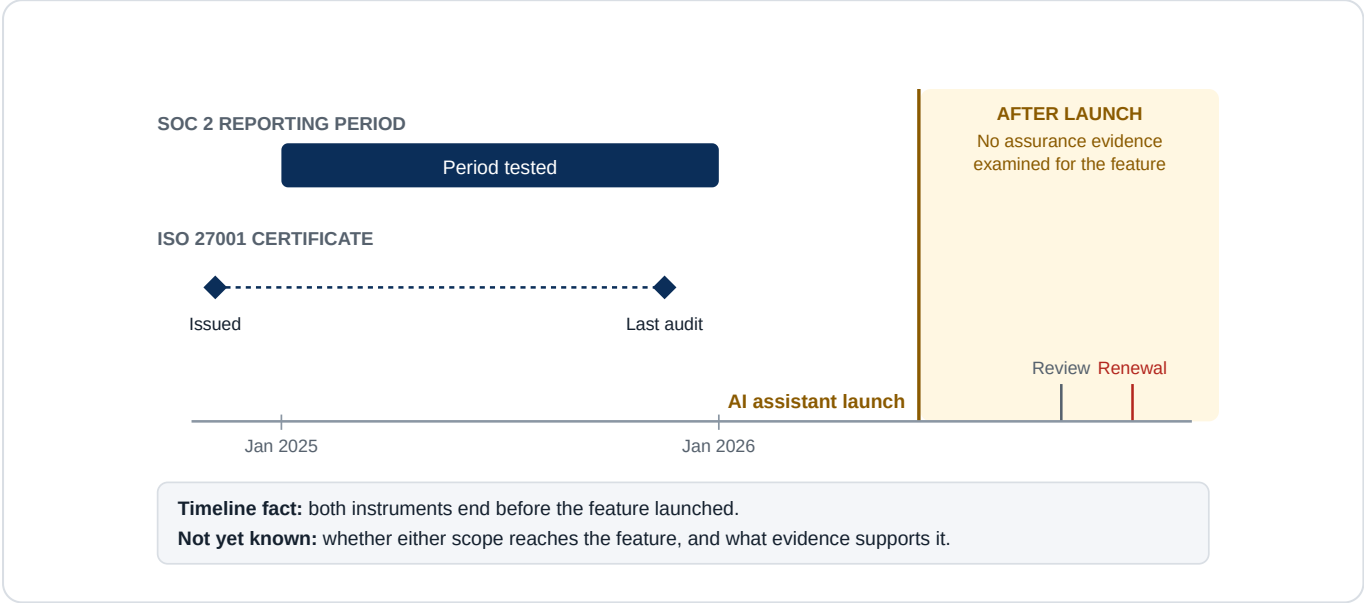
The data-flow position is unclear. The only basis for any flow to the model provider is the provider's own documentation.

NOT ESTABLISHED Whether the bank's data reaches it, or is retained or used for training, is not established. Nothing was tested.

The feature is on by default. **NOT ESTABLISHED** Whether it is active in the bank's tenant, or anyone has used it, is not established. A feature that exists is not a feature that is switched on.

Disabling may not mean what it sounds like. The provider says the assistant can be disabled. The opt-out wording does not explain what happens to data. **NOT ESTABLISHED** Whether the switch stops the underlying data flow, or only hides the assistant from users, is not established.

The renewal date puts pressure on the decision. It is not evidence against the provider.



Illustrative dates, to scale. The SOC 2 period and the ISO dates sit before the launch. That is a timeline fact. It says nothing yet about scope.

The decision **PROPOSED**

Restrict pending verification.

Confirm the assistant's state in the bank's tenant and disable it now. Treat the feature as contained only when evidence establishes that disabling it stops the relevant data flow.

The decision gate is 26 November, before the 11 December renewal. If that evidence is not in by then, negotiate a short renewal with the assistant excluded. Exit planning starts only if the provider cannot or will not provide the evidence.

Can the bank rely on the existing assurance? Not yet, for this feature. The assurance is treated as valid. The open question is whether it provides evidence for this one.

Continuing means renewing on assurance nobody has examined for this feature. Exiting is the highest-cost option: migrating case history, rebuilding integrations, running two systems in parallel and retraining staff. It is unlikely to finish in 60 days.

What would move the decision

- 1. Towards continuing:** the scope documents name the assistant, evidence dated after launch supports it, the contract position on the model provider is documented, and disabling is shown to stop the flow.
- 2. Towards exit planning:** the provider declines to give the evidence, or data still flows after disabling and the provider cannot correct it.

Free template: the SaaS AI Assurance-Scope Check is at aiforui.org/downloads/case-03-saas-ai-assurance-scope-check-template.xlsx. Full case: aiforui.org/cases/case-03.

Reference. This case does not rely on any regulatory requirement. Any Qatar-specific requirement is for Legal and Compliance to confirm. The reasoning is professional opinion on simulated facts.